On crée un "point d'entrée" de session personalisé sur le serveur A. En se connect via ce point d'entrée notre TGT est correctement mis en cache ce qui resous le prob em du double saut. Mais ca demande des privilèges élevés et une vrai console winRM pas un evil-winrm.
Voici la procédure sous forme de commandes...

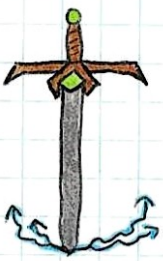
[1]_ On se connecte au serveur A depuis notre machine d'attaque:
PS C:\attacker> Enter-PSSession -ComputerName DEV01 -Credential DO
AIN\usernamepwn

[2]_ Sur notre session obtenue sur serverA on configure point de terminaison et r redemarre le service.
PS C:\DEV01> Register-PSSessionConfiguration -Name 'malobsession' -Ru
Credential DOMAIN\usernamepwn
PS C:\DEV01> Restart-Service WinRM

[3]_ Sur notre machine d'attaque on execute la connexion finale a cette sessio qui pourra joindre le serveur B sans problem:
PS C:\attacker> Enter-PSSession -ComputerName DEV01 -Credential DOM
N\username -ConfigurationName malobsession

Quelques Vulnérabilités de pointe :

On peux citer quelques vulnérabilités mais elles ne sont plus si récentes il est meam ains possible de trouver des system qui y soient encore vulnérable



- On a Sam_The_Admin egalement appelé NoPac cette vulnerabilité tire pa de changer le samAccountName = (username de login) d'un compte utilisateu pour celui du contrôleur de domain. Ensuite on demande des TGS qui seront dél res au nom du DC permettant un accès system il esciste plusieurs scripts d'escp tation disponibles...

- PrintNightmare est le surnom donné a deux vulnérabilités trouvés dans le spooler d'impression qui s'execute sur tout les OS windows, forcant la victim a se connecter à un partage reseau piégé.

- PetitPotam, une faille permettant à un attaquant non authentifié de forcer le contrôleur de domain à s'authentifier auprès d'un Rote en utilisant NTLM. Si cette requete est relayé sur endpoint ADCS = compromission total du domaine.

Mauvaises Configuration Diverses :

① _ Sniffing d'identifiants LDAP.
De nombreuse applications ou imprimantes utilisent un compte pour se connect à l'annuaire LDAP. Les identifiants sont parfois stockés en clair dans des consoles d'administrations web mal-sécurisée. Une autre technique consiste (une fois sur le pannel web evidemment) à utiliser la fonctionnalité "tester la connexion" en remplac nt l'IP du serveur LDAP par notre IP attaquant ou tourne un ncat sur le port 38 prêt à capturer les identifiant envoyés.

② _ Enumération des Enregistrements DNS.
Par default les utilisateurs du domain peuvent lister les enregistrements DNS via LDAP. L'outil adidnsdump automatise ce processus pour découvrir des noms d'hotes "cachés" ou plus discriptif qui ne sont pas evident via une enumeration standar
Exemple de commande

```
Agentpathogene@parrot ~$ adidnsdump -u DOMAIN\\username ldap://IP.du.D
```